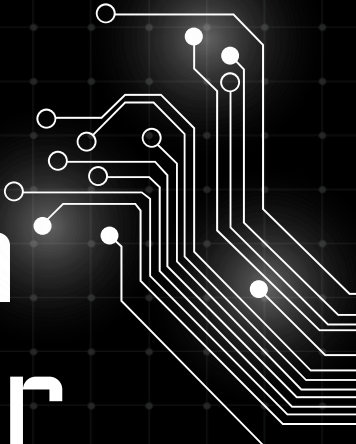
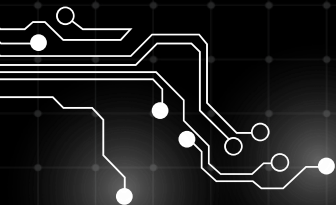
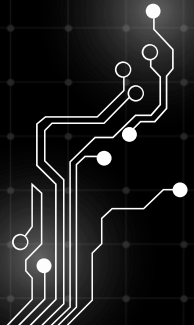




Optimisation de la gestion du MFA sur Microsoft Entra ID



Répondre aux incidents et aux demandes

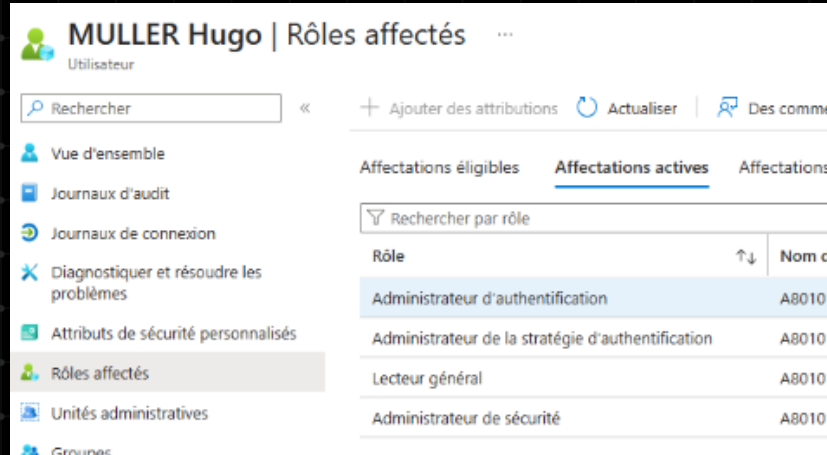
Contexte

- **Objectif initial** : Sécuriser les accès en supprimant les droits "**Administrateur Général**" pour la gestion quotidienne du MFA.
- **Groupe visé** : Le groupe **AzureAdmin_CSI** possédait des privilèges trop élevés (**Domain Admin**) par rapport aux besoins du support.
- **Problématique** : Identifier précisément le **rôle minimal** requis pour l'upload et la gestion des **jetons matériels OATH**.



Rôle

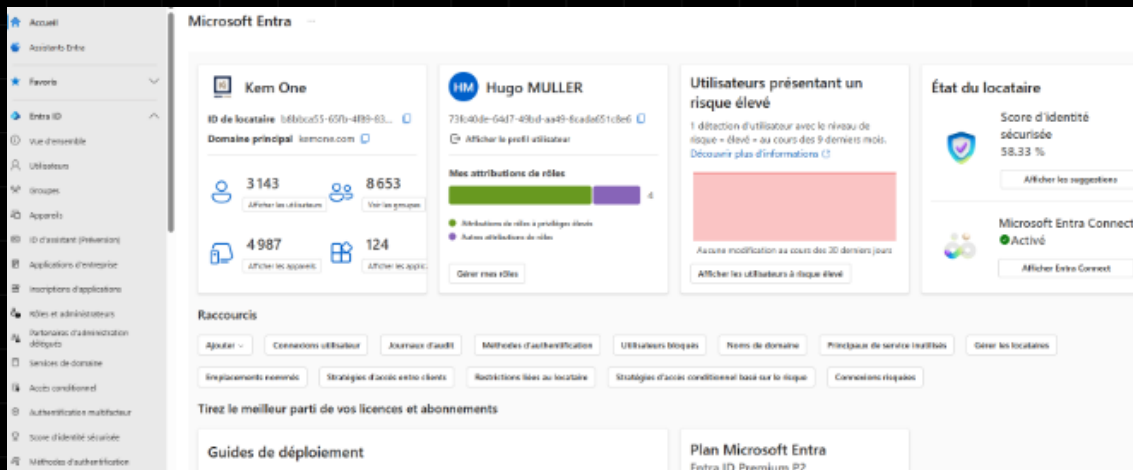
- **Analyse documentaire** : Recherche approfondie sur les **rôles intégrés** Microsoft Entra ID.
- **Élaboration d'hypothèses** : Définition de **8 scénarios** de tests unitaires pour isoler les permissions nécessaires.



Hypothèse 1	Le rôle minimum pour charger un jeton OATH sur Entra ID est le rôle Administrateur de la stratégie d'authentification
Hypothèse 2	Le rôle minimum pour charger un jeton OATH sur Entra ID est le rôle Administrateur d'authentification
Hypothèse 3	Le rôle minimum pour charger un jeton OATH sur Entra ID est le rôle Administrateur de sécurité
Hypothèse 4	Les rôles minimums pour charger un jeton OATH sur Entra ID sont Administrateur de la stratégie d'authentification et Administrateur d'authentification
Hypothèse 5	Les rôles minimums pour charger un jeton OATH sur Entra ID sont Administrateur de la stratégie d'authentification et Administrateur de sécurité
Hypothèse 6	Les rôles minimums pour charger un jeton OATH sur Entra ID sont Administrateur de sécurité et Administrateur d'authentification
Hypothèse 7	Les rôles minimums pour charger un jeton OATH sur Entra ID sont Administrateur de la stratégie d'authentification, Administrateur d'authentification et Administrateur de sécurité
Hypothèse 8	Le rôle minimum pour charger un jeton OATH sur Entra ID est le rôle Administrateur d'authentification privilégié

Compétences acquises

- **Administration Cloud** : Gestion des identités et des accès via la console **Microsoft Entra ID**.
- **Sécurité offensive/défensive** : Mise en œuvre concrète du principe de **moindre privilège**.
- **Méthodologie** de test : Conception et réalisation de **plans de tests unitaires** pour valider des habilitations.
- **Expertise technique** : Capacité à confronter la **documentation éditeur** à la réalité du terrain.



Difficultés

- **Contradiction documentaire** : Écarts constatés entre la **documentation Microsoft** et les preuves obtenues en environnement de test.
- **Protection hiérarchique** : Identification de l'impossibilité technique pour un admin standard de gérer le MFA d'un **compte de rang supérieur**.

🔍 Rechercher par rôle										
Rôle	📄	Nom du principal	Portée	📄	Appartenance	📄	État	Heure de début	Heure de fin	Action
Administrateur d'authent...			Répertoire		Direct		Active	-	Permanent	Supprimer Mettre à jour
Administrateur général			Répertoire		Direct		Active	-	Permanent	Supprimer Mettre à jour
Administrateur de l'accès...			Répertoire		Direct		Active	-	Permanent	Supprimer Mettre à jour
Administrateur de la strat...			Répertoire		Direct		Active	-	Permanent	Supprimer Mettre à jour
Administrateur SharePoint			Répertoire		Direct		Active	-	Permanent	Supprimer Mettre à jour
Administrateur des desti...			Répertoire		Direct		Active	-	Permanent	Supprimer Mettre à jour
Lecteur général			Répertoire		Direct		Active	-	Permanent	Supprimer Mettre à jour
Administrateur Exchange			Répertoire		Direct		Active	-	Permanent	Supprimer Mettre à jour



Rendu final

- **Compte rendu de synthèse** : Document récapitulant les observations et les **résultats validés** des différents tests d'hypothèses.
- **Plan d'action** : Recommandation officielle de basculer le support vers le rôle "**Administrateur d'authentification privilégié**".

Plan d'Action

Voici un plan d'action à suivre pour vérifier nos hypothèses.

1. Créer un utilisateur de test temporaire
 2. Lui attribuer les rôles en fonction de l'hypothèse traitée
 3. Noter les hypothèses qui fonctionnent
 4. Il est fortement probable que plusieurs hypothèses soient juste, ne garder que celles dont le nombre de rôle attribué à l'utilisateur est le plus bas
 5. Conclure sur le rôle minimum permettant de gérer les jetons OATH sur le MFA de l'Entra ID
 6. Adapter les rôles donnés au support
- 